第三章 SQL 注入漏洞与防护

实验分析报告

项目	内容
班级	24 信安 02
姓名	李文
学号	2403460224
实验环境	本机浏览器 + DVWA + localhost/127.0.0.1 或教师明确授权环境
提交文件名	2403460224 李文 SQL 注入漏洞与防护.pdf / .docx

授权边界说明

本报告仅分析 DVWA、本机浏览器、localhost/127.0.0.1 或教师明确授权环境中的实验现象；不包含、也不支持对公网真实目标进行 SQL 注入探测、验证或攻击。

报告主线与核心结论

主线：输入 → 拼接 → 解析 → 执行 → 回显/行为差异 → 结构分离防护。
核心结论：SQL 注入的根因不是某几个字符“天生危险”，而是用户输入进入了不该进入的查询结构，使数据库在解析阶段把输入内容当成了 SQL 结构的一部分。

任务完成度对照说明

评分要求	本文对应位置	完成情况
任务 1：数据库与查询条件基础说明	第一节：业务链路、输入进入查询条件、注入可能性	已覆盖
任务 2：Low 现象记录	第二节：普通输入/异常输入对比、返回差异解释	已覆盖
任务 3：机制分析与差异比较	第三节：链条、根因、Low/Medium、普通注入/盲注、强制判断题	已覆盖
任务 4：防护清单与解释	第四节：参数化、输入校验、错误处理、最小权限等分层说明	已覆盖
收口项：关系表、自评、AI 审核	第五至第七节	已覆盖

一、数据库与查询条件基础说明

以 DVWA 中的“根据 User ID 查询用户信息”功能为例，页面中的输入框并不是孤立存在的控件，而是业务查询链路的入口。用户输入的 User ID 会通过浏览器提交到后端，后端把它作为查询条件访问数据库，并把数据库返回的数据展示给用户。

最小业务链路可以概括为：输入条件 → 数据库查询 → 返回结果。页面负责收集查询条件，数据库负责保存和检索真实数据，后端代码则位于两者之间，负责接收输入、构造查询、处理结果。

用户输入进入查询条件的常见方式是：浏览器把输入放入 GET 参数或 POST 请求体，后端程序通过变量接收这些值，再把它们放入 SQL 的 WHERE 条件中。例如用户资料查询功能中，输入值可能会进入 user_id 条件。

SQL 注入的可能性来自“不安全的字符串拼接”。如果后端直接把用户输入拼进 SQL 语句，数据库在解析完整语句时就可能无法区分“这是普通数据值”还是“这是新的查询结构”。一旦输入突破原本的数据边界，WHERE 子句的过滤逻辑就可能被污染。

环节	业务含义	在本实验中的体现	风险点
输入条件	用户提交业务查询条件	输入 User ID，例如 2	输入内容可能未经严格约束
数据库查询	后端根据条件访问数据库	查询 users 表中对应 user_id 的用户信息	查询条件可能由拼接产生
返回结果	数据库结果经后端返回页面	页面显示 first_name 与 last_name	异常回显可能暴露查询逻

环节	业务含义	在本实验中的体现	风险点
			辑
风险入口	输入参与查询构造	输入不再只是数据，而可能影响 WHERE 条件	数据与结构边界混淆

二、DVWA SQL Injection Low 现象记录

实验目标：在本地或教师授权的 DVWA 环境中进入 SQL Injection 模块，将安全级别设置为 Low，观察普通输入与异常输入导致的返回结果差异。实验仅用于课程授权环境，不对公网真实目标进行验证。

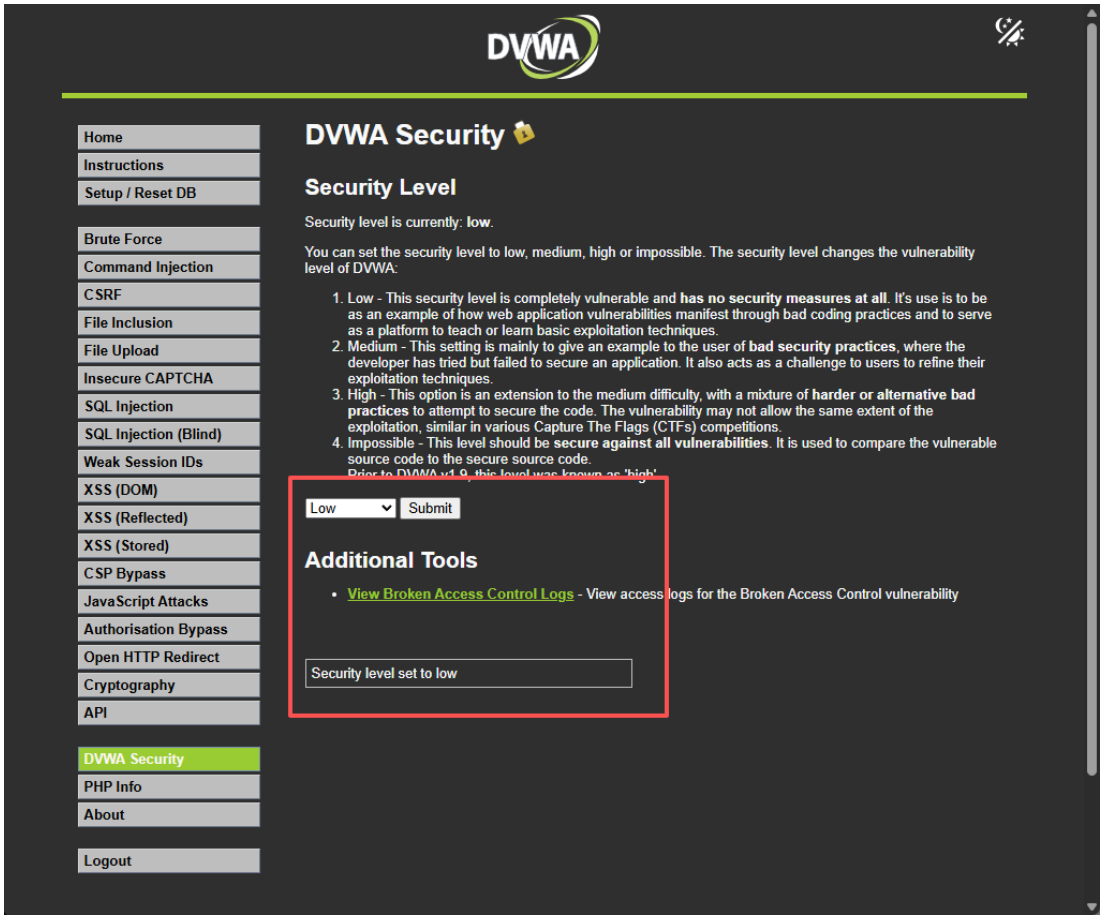

图 1 DVWA 安全等级设置为 Low 的实验环境截图

证据说明

图 1 用于证明实验环境处于 DVWA 的 Low 安全级别，后续现象均限定在本机/授权靶场内，不代表对真实公网目标进行测试。

1. 普通输入与异常输入对比

输入类型	输入内容	页面表现	判断依据
普通输入	2	页面按预期只返回 ID 为 2 的用户信息，例如 Gordon Brown。	WHERE 条件仍在按单个 ID 过滤。
异常输入	2' or '1'='1	页面返回多条用户记录，超出单个 ID 查询范围。	输入影响了查询逻辑，而不只是改变了一个查询值。

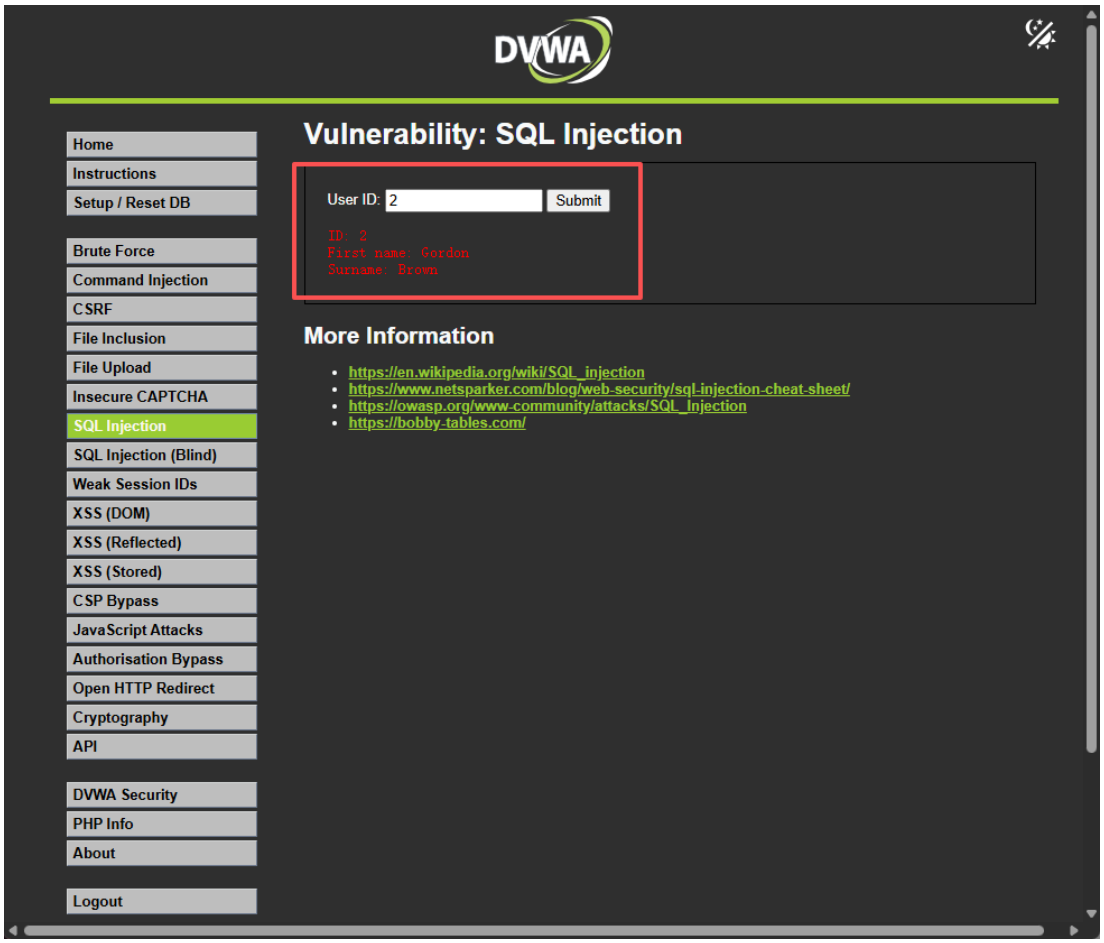

图 2 Low 模块普通输入与实验过程截图

证据说明

图 2 体现普通输入下的正常业务路径：输入值作为单个查询条件，返回结果范围与业务预期一致。

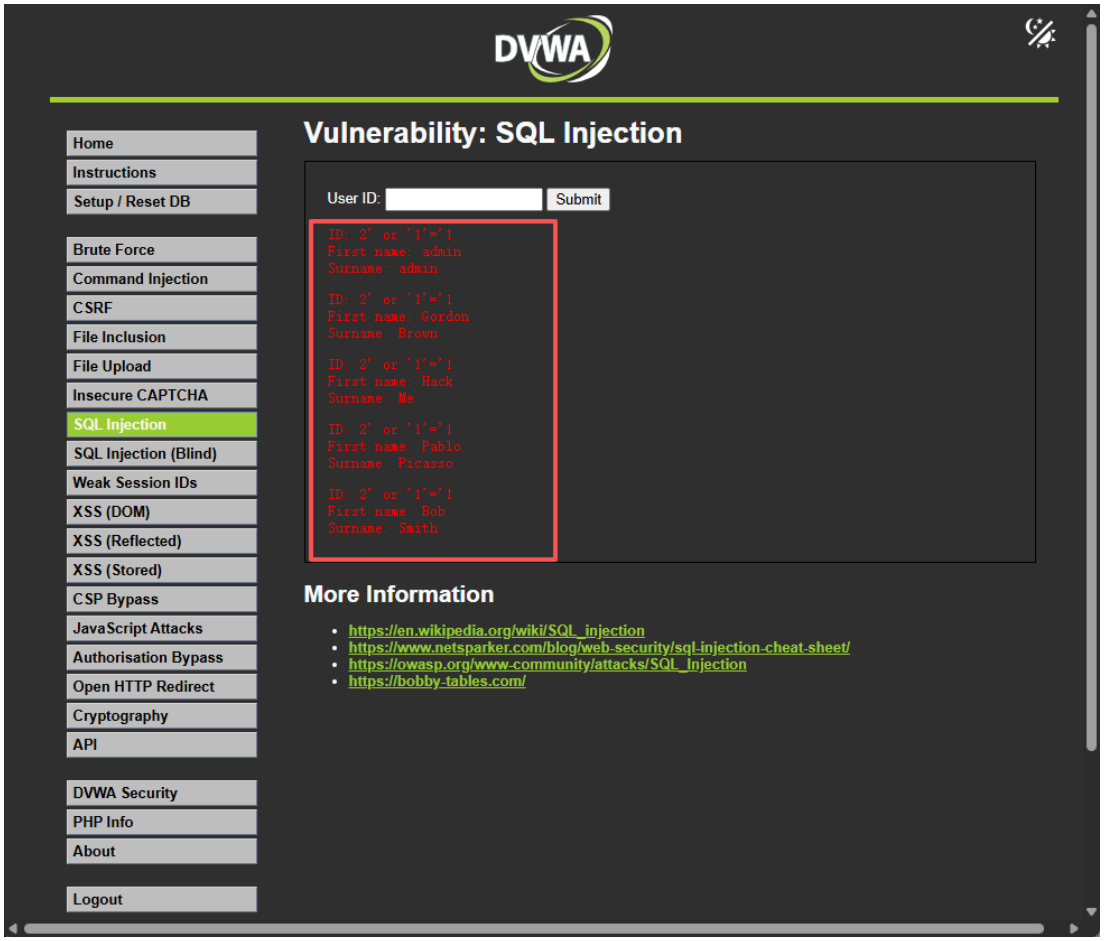

图 3 Low 模块异常输入与返回差异截图

证据说明

图 3 体现异常输入后返回结果范围扩大，说明 WHERE 条件的过滤作用被改变；该现象支撑“查询结构被污染”的判断。

2. 为什么这种差异不像正常查询变化

如果只是把 ID 从 2 改成 3，业务语义仍然是“查询另一个单一用户”，返回结果通常只是在具体用户上发生变化。异常输入后返回多条用户记录，说明过滤边界已经不再按照单个 ID 工作，页面结果不是正常业务条件变化，而是查询逻辑被重新解释后的结果。

该差异支撑的判断是：问题不在于某个字符本身具有破坏性，而在于输入被拼接进查询语句后，影响了数据库对 WHERE 子句的解析和执行。

三、机制分析与差异比较

1. 输入—拼接—解析—执行—回显/行为差异链条

本实验的核心链条是：输入 → 后端变量接收 → 字符串拼接 → 数据库解析 → 执行被改变的查询结构 → 页面产生异常回显或行为差异。这个链条说明，漏洞不是只发生在页面输入层，而是在输入参与查询构造并被数据库解析时真正形成。

阶段	发生了什么	对应证据/现象
输入	用户提交普通 ID 或构造后的输入	普通输入与异常输入形成对比
拼接	后端把输入合入 SQL 条件	输入不再只停留在页面层
解析	数据库把拼接后的整体当作 SQL 语句解析	WHERE 逻辑可能被改变
执行	数据库执行改变后的查询结构	返回超出预期的数据范围
回显/行为	页面直接显示数据、报错，或只显示 True/False 状态	普通注入与盲注的证据形式不同

2. 根因：结构被污染，而不是字符本身危险

单引号、OR 等字符作为普通文本保存时并不会天然造成危害。真正的问题是后端没有把“数据”和“查询结构”隔离，导致输入有机会参与 SQL 语法解析。一旦输入从数据位置进入结构位置，数据库解析出来的查询结构就可能偏离开发者原本设计的逻辑。

因此，本章的根因应表述为：查询结构被用户输入污染，而不是“某几个字符天生危险”。Medium 级别中即使不依赖单引号，也可能通过数字型条件中的逻辑表达改变查询结构，这进一步说明根因在结构层。

3. Low 与 Medium 的差异

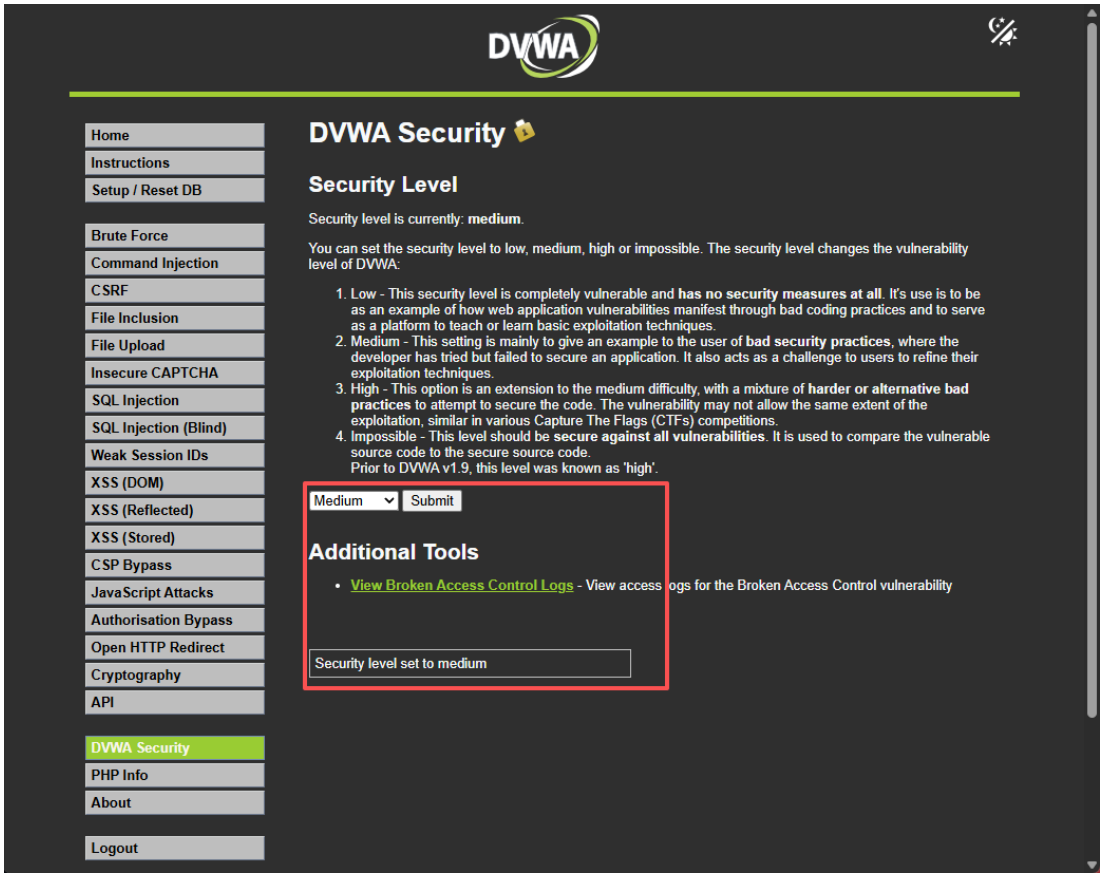

图 4 Medium 级别控制方式实验截图之一

证据说明

图 4 说明 Medium 级别并非没有控制措施，而是加入了前端限制或局部处理；但这些措施主要属于暴露面控制，不等于结构分离。

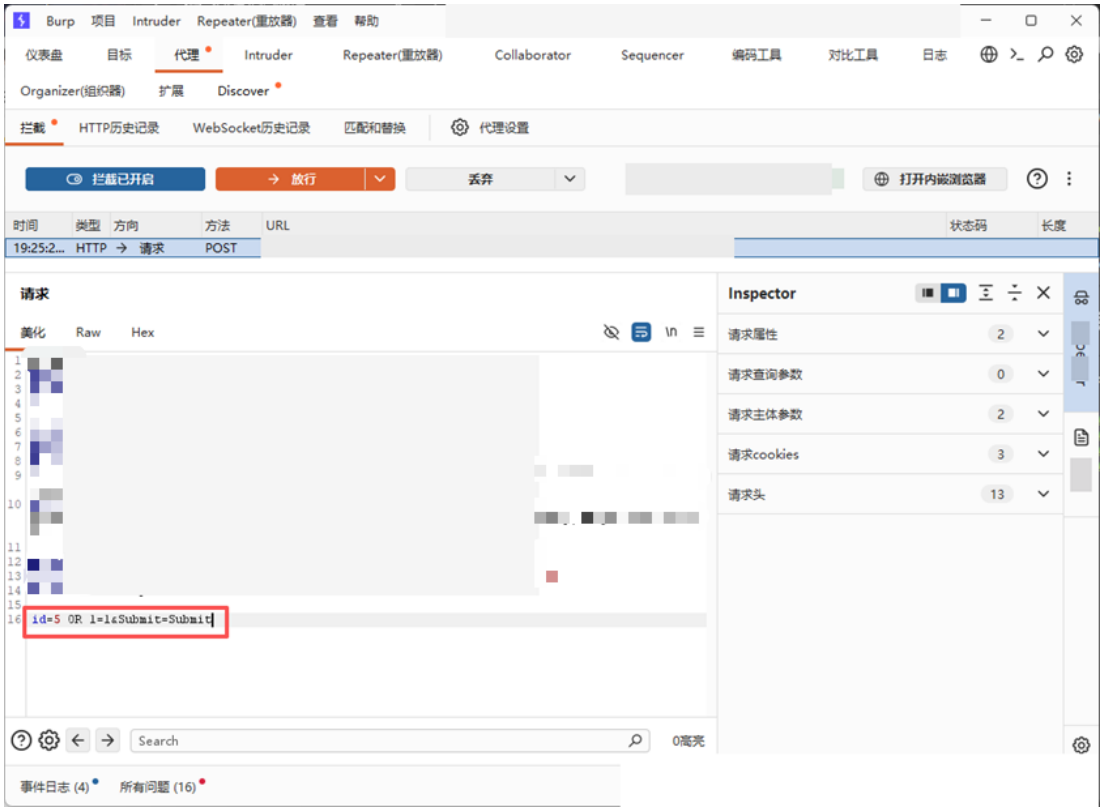

图 5 Medium 级别请求修改/抓包验证截图

证据说明

图 5 说明前端控件限制不能被视为可靠边界，底层请求仍可能被修改；安全控制必须落实在服务端查询构造层。图中非必要 Host/Cookie 信息已遮蔽。

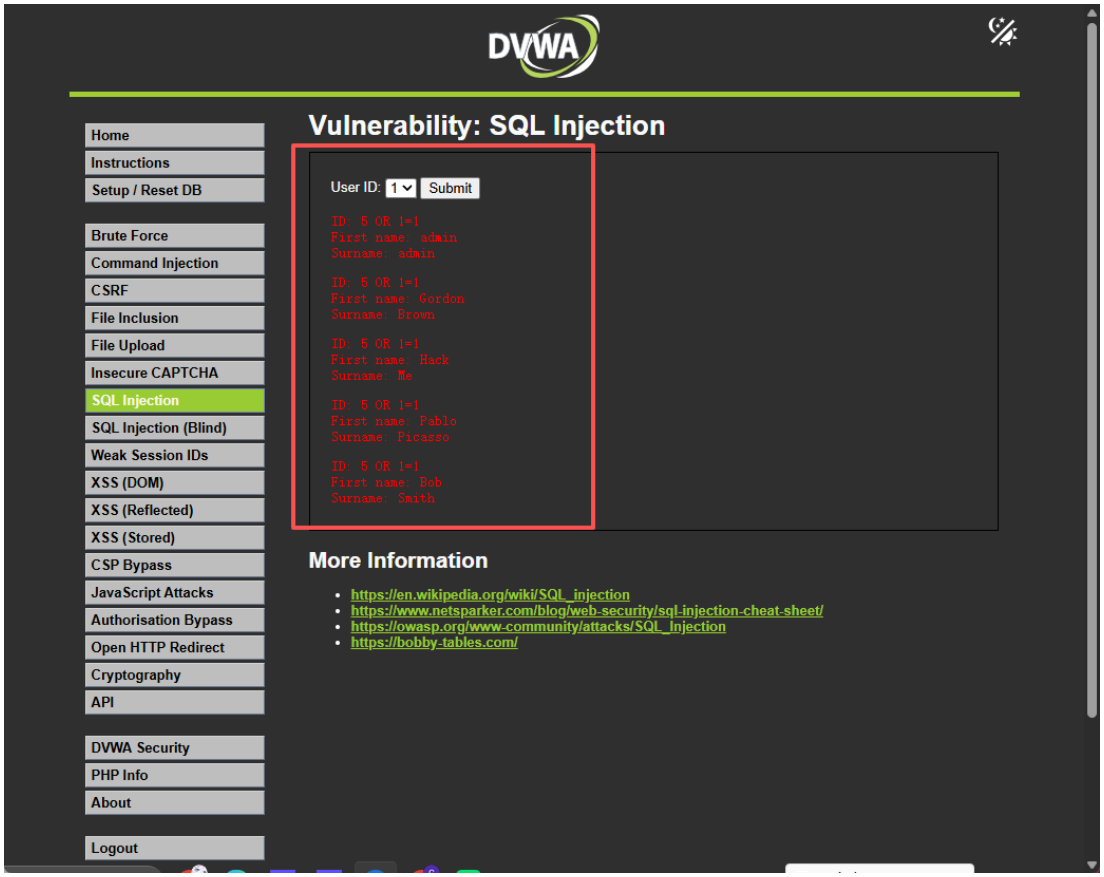

图 6 Medium 级别返回差异或行为证据截图

证据说明

图 6 用于支撑 Medium 级别下仍可能出现返回范围异常的判断，说明局部转义或前端限制不能替代参数化查询。

比较项	Low	Medium	分析结论
输入入口	通常直接从请求参数读取输入	页面可能使用下拉框等前端限制，并改用 POST 提交	前端限制只能降低误操作，不能作为根因防护。
后端处理	更明显地把输入拼接进 SQL	可能增加转义等处理，但数字型拼接仍可能被逻辑表达污染	转义不是参数化查询，不能稳定分离数据与结构。
绕过风险	异常输入直接改变字符串型条件	可通过请求层修改前端不允许的内容	控制点必须放在服务端和查询构造层。
本质差异	几乎无有效过滤	有一定表层限制和局部处理	Medium 是暴露面控制尝试，不等同于根因控制。

综合来看，Low 与 Medium 的差异主要体现在控制思路上：Low 更接近直接暴露不安全拼接；Medium 尝试通过前端限制、提交方式变化或局部转义降低异常输入进入的概率。但是，只要查询构造仍未完成数据与结构的分离，结构污染风险就没有被根本消除。

4. 普通 SQL 注入与 Blind SQL Injection 的差异

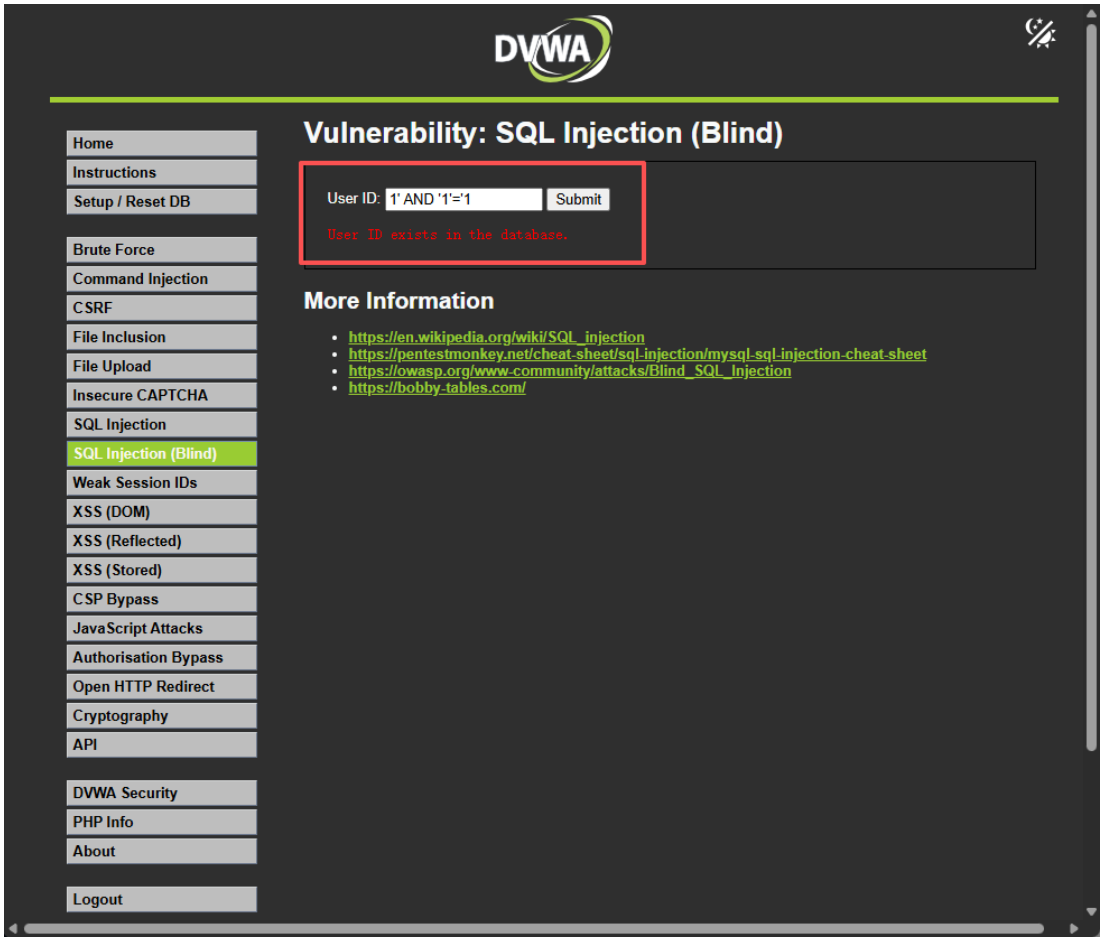

图 7 Blind SQL Injection 为真时的行为证据截图

证据说明

图 7 体现盲注条件为真时页面给出的状态反馈；证据不是直接数据回显，而是行为差异。

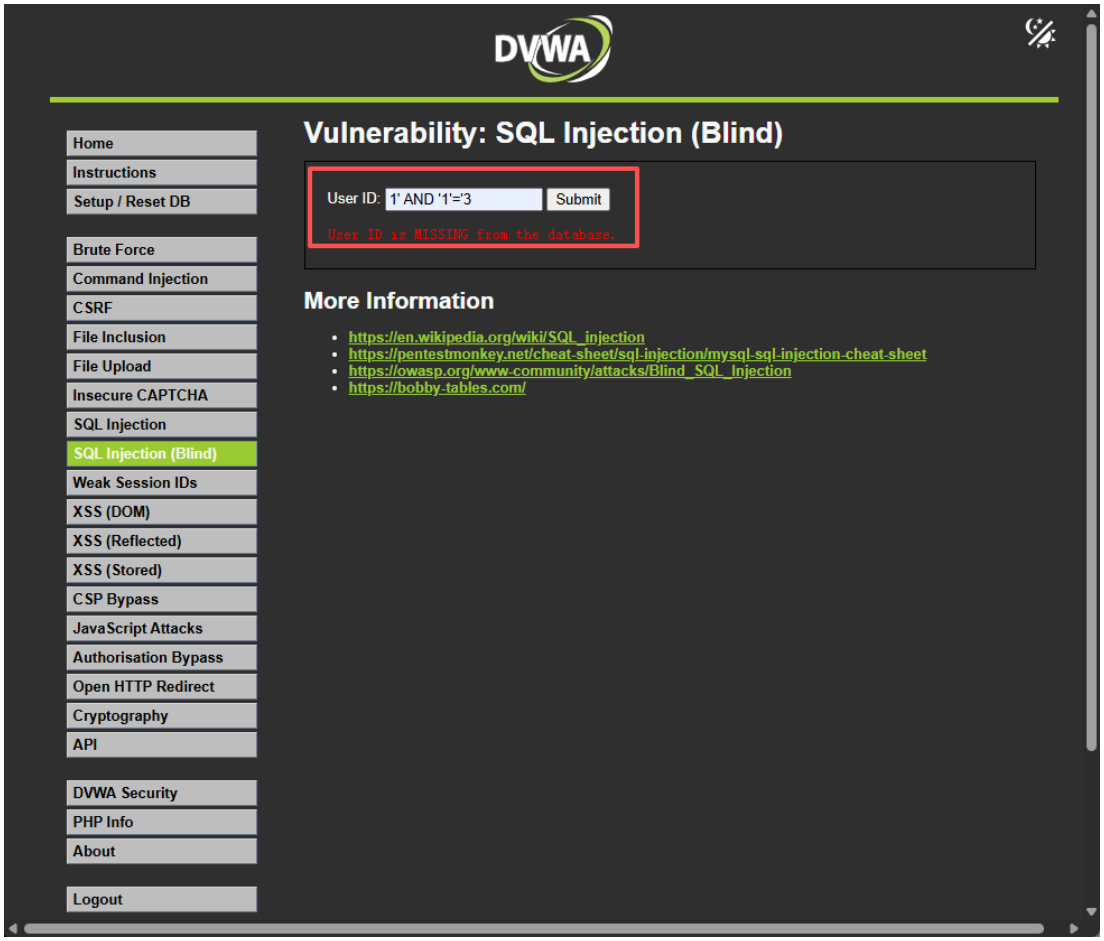

图 8 Blind SQL Injection 为假时的行为证据截图

证据说明

图 8 体现盲注条件为假时页面状态不同，与图 7 形成对照，说明查询逻辑仍能被输入影响。

普通 SQL 注入与盲注的漏洞根因相同，都是用户输入进入了不该进入的查询结构。二者的主要差异在证据层：普通注入可能直接回显数据库内容或错误信息；盲注通常不直接显示数据，只通过 True/False、页面内容变化、响应时间变化等行为差异提供侧信道证据。

因此，盲注不是“另一种根因”，而是在回显受限时通过行为差异继续证明查询逻辑可被影响。

5. 强制判断题

判断题	选择	理由
SQL 注入的根因更接近：A. 输入里有几个危险字符；B. 输入进入了不该进入的查询结构	B	危险不在字符本身，而在输入被当成查询结构的一部分解析。

判断题	选择	理由
Blind SQL Injection 和普通 SQL 注入最大差异更接近：A. 根因不同；B. 证据形式不同	B	二者底层都是结构被污染，只是页面是否直接回显数据不同。

四、SQL 注入防护清单与解释

防护不能只写成“过滤危险字符”。应当按控制层级区分：参数化查询对应根因控制；输入校验、错误处理主要降低暴露面；最小权限用于缩小后果范围；日志监控用于发现和追溯异常行为。

防护措施	解决什么问题	控制层级	不能替代什么
参数化查询 / 预编译	把 SQL 模板与用户输入分离，用户输入只作为参数值绑定，不参与改变语句结构。	根因控制	不能替代业务授权、越权校验和审计。
输入校验 / 白名单	限制类型、长度、格式，例如 ID 只能是正整数，减少异常输入进入业务逻辑的机会。	暴露面控制	不能替代参数化查询；复杂业务输入无法只靠过滤保证安全。
统一错误处理	避免把数据库错误、表名、路径、堆栈等信息直接暴露给前端。	暴露面控制 / 证据压缩	不能修复漏洞本身；攻击者仍可能通过盲注观察行为差异。
最小权限	应用使用低权限数据库账号，限制可访问库表与可执行操作，降低成功注入后的损害。	后果范围缩减	不能阻止注入发生，也不能保护已授权访问的数据。
日志监控与告警	记录异常参数、频繁错误、布尔/时间差异探测等行为，便于发现和处置。	检测与响应	不能替代代码层修复，只能帮助发现与追溯。

其中，参数化查询是最接近根因的控制点，因为它让数据库在解析阶段先确定 SQL 结构，再把用户输入作为参数值处理。输入校验和错误处理有价值，但它们主要减少异常输入和敏感回显，并不能从根本上保证查询结构不被污染。最小权限也非常必要，但它解决的是“发生问题后损害多大”，不是“漏洞是否存在”。

五、SQL 注入因果链 / 防护关系表

阶段/节点	行为与现象	证据或判断	防护控制点	控制层级
输入点	用户在页面或请求中提交查询条	普通输入与异常输入可对比	输入校验、类型限制	暴露面控制

阶段/节点	行为与现象	证据或判断	防护控制点	控制层级
	件			
查询构造	后端把输入拼接到 SQL 条件中	数据边界与语句结构混在一起	参数化查询、ORM 安全绑定	根因控制
数据库解析/执行	数据库按完整 SQL 语句解析并执行	WHERE 子句可能被永真逻辑影响	参数化查询从源头避免结构污染	根因控制
结果差异/行为证据	页面返回多条数据、报错或 True/False 差异	证明查询逻辑受到输入影响	统一错误处理、减少敏感回显	暴露面控制
后果范围	可能出现越权读取、批量泄露或更高风险操作	影响取决于数据库权限	最小权限、分库分权、审计	后果范围缩减

该关系表体现的结论是：SQL 注入不是单点问题，而是从输入进入查询结构开始，经数据库解析执行后，在回显或行为层形成证据。防护也应形成链条，不能只依赖某一个过滤规则。

六、学生自评表

问题	自评内容
我本章最清楚的一点是什么?	我本章最清楚的一点是：SQL 注入的核心问题不是某个字符本身危险，而是用户输入被后端拼接进了 SQL 查询结构中，导致数据库在解析时把输入的一部分当成了 SQL 逻辑。通过 Low 级别中普通输入和异常输入返回结果的对比，我能更直观地理解“查询结构被污染”这一根因。
我最容易混淆的一点是什么?	我最容易混淆的是“过滤、转义、前端限制”和“真正防护”之间的区别。开始时我容易认为 Medium 级别增加了下拉框或转义处理后就比较安全，但通过请求层修改和返回结果对比后，我认识到这些措施主要是降低暴露面，并不能替代参数化查询。真正的根因控制应当是让用户输入始终作为数据值，而不是参与 SQL 结构解析。
我本次作业中哪一段最需要教师复核?	我最希望教师复核的是第三节中关于 Low 与 Medium 差异的分析，尤其是“前端限制不能作为可靠安全边界，控制点必须放在服务端查询构造层”这一判断。因为这部分涉及从实验现象推导防护层级，我希望确认自己的因果链是否严密，是否准确区分了暴露面控制和根因控制。
如果重做一次，我会优先改哪一部分?	如果重做一次，我会优先补强 Blind SQL Injection 部分的证据记录。当前报告主要通过 True / False 页面状态差异说明盲注证据形式，如果时间更充足，

问题	自评内容
	我会进一步记录不同条件下的响应内容或响应时间变化，使“没有直接回显，但仍能通过行为差异判断查询逻辑被影响”这一结论更加充分。

通过本次实验，我意识到安全分析不能只停留在 payload 表面，而要把输入、查询构造、数据库解析、页面回显和防护控制点连成完整因果链来判断。

七、AI 输出审核与人工复核记录

审核项	记录
本作业哪些内容使用过 AI 辅助	使用 AI 辅助梳理报告结构、优化表格表达，并对“因果链/防护关系表”的层级进行语言润色。
哪些判断是自己复核后保留的	关于“结构污染是根因”“普通注入与盲注主要是证据形式不同”“参数化查询对应根因控制”等判断，均结合 DVWA 实验现象和课程主线复核后保留。
哪些 AI 输出不准确并进行了修正	对“输入校验能防止注入”“错误处理能解决注入”等过于笼统的说法进行了修正，改为区分根因控制、暴露面控制和后果范围缩减。
如何确认结论和证据一一对应	逐项核对普通输入、异常输入、Low/Medium 差异和盲注 True/False 行为证据，确保每个结论都能对应到截图或实验现象，而不是只写概念。

八、提交前自查清单

自查项	状态
确认实验范围仅限 DVWA、本机浏览器、localhost/127.0.0.1 或教师明确授权环境。	已确认
确认截图中不包含公网真实目标、真实账号、Token、Cookie、完整会话标识等敏感信息。	已确认
确认每张截图后均有“证据说明”，能说明该图支撑什么判断。	已确认
确认报告将根因写成“查询结构被污染”，而不是只写“特殊字符危险”。	已确认
确认普通注入与盲注的差异被表述为“证据形式不同”，而不是“根因不同”。	已确认
确认防护措施区分了根因控制、暴露面控制、后果范围缩减与检测响应。	已确认

最终责任声明

本报告中的实验与截图均仅来源于本机 DVWA 或教师授权环境。